

V.I.P.E.R. — Information Security & Compliance Policy Guide

Aligned to the NIST Cybersecurity Framework (CSF v1.1)

Product: V.I.P.E.R. (Versatile Investigative Platform for Enforcement Records) **Vendor:** Intellect LE, LLC
Document Version: 1.2 **Aligned to:** NIST CSF v1.1 / MS-ISAC Policy Template Guide (2020) **Status:** Template — agencies should customize sections marked **[AGENCY-SPECIFIC]**

⚠️ READ FIRST — Vendor Boundary & Offline Architecture

VIPER is an offline, locally-installed desktop application. Intellect LE, LLC has no access to agency case data at any point in the product lifecycle. This is by design.

The agency owns and controls every byte of case data, evidence, warrant returns, and derivative work product produced inside VIPER. The vendor cannot see it, retrieve it, decrypt it, copy it, or destroy it remotely. This is not a service limitation — it is a deliberate architectural choice that keeps CJIS-classified information inside the agency's existing CJIS perimeter.

What Intellect LE CAN See (limited to licensing)

- Installation registration: customer organization name, license-key **hash**, product version, last-seen timestamp, and the IP address from which validation was requested.
- License-validation pings (version + license-key-hash + nonce — no case payload of any kind).
- Voluntary, opt-in error reports if the agency enables them (off by default).

What Intellect LE CANNOT See — Ever

- Case files, case numbers, case content, evidence files, narrative text.
- Identities of witnesses, victims, suspects, missing persons, or any other subject.
- Warrant returns (KIK, Google, Discord, Snapchat, Meta) or anything parsed from them.
- Officer notes, audit-log contents, custom-metric values, or operations plans.
- Master passphrases, encryption keys, or any data protected by Field Security (AES-256-GCM; the key is derived from the user's passphrase and never leaves the device).
- Local file-system contents, local network state, local user accounts, or installed peripherals.
- Whether a given case, evidence file, or warrant return exists, has been deleted, or has been exported.

Vendor Role in CJIS Compliance — None

Intellect LE is not a CJIS service provider. VIPER does not store, transmit, view, or process CJIS-classified data on any vendor-controlled infrastructure. CJIS data never leaves the agency's control by passing through VIPER.

The controlling authority over CJIS data on every workstation that runs VIPER is the **agency's CJIS**

Security Policy, derived from the **FBI CJIS Security Policy (CJISD-ITS-DOC-08140)** and administered by the agency's **CJIS Systems Officer (CSO)** and **Local Agency Security Officer (LASO)**. Those officials retain full and exclusive authority over:

- Personnel screening and access authorization (CJIS §5.12)
- Auditing of access to CJIS data (CJIS §5.4)
- Physical security of the host workstation (CJIS §5.9)
- Incident response and breach notification (CJIS §5.3)
- Media protection, retention, and destruction (CJIS §5.8)
- Reporting to the State CJIS Systems Agency (CSA) and to the FBI CJIS Division

This guide complements — it does not replace — the agency's CJIS Security Policy. **Where any conflict exists, the agency CJIS Security Policy and the FBI CJIS Security Policy govern.**

Vendor Role in Incident Response — Strictly Bounded

Intellect LE cannot lead, assist with, or participate in incident-response operations involving agency case data. We have no access to:

- The contents of the affected installation
- Local audit logs (stored only on the agency device)
- Encrypted case files (only the user's passphrase can decrypt them)
- Information about which subjects, victims, suspects, or cases are affected

In the event of a confirmed or suspected data breach involving a VIPER installation, the **agency leads the response** under its existing CJIS-compliant incident-response plan. The vendor's role is strictly limited to:

1. Confirming whether the application's build pipeline and code-signing chain remain intact (supply-chain side only).
2. Issuing license revocations on documented agency request.
3. Supplying reference documentation (this guide, the build manifest, the dependency manifest) to support the agency's own forensic and notification work.

Vendor Role in Breach Notification — None

We have no ability to perform breach notifications on the agency's behalf, and we are not contractually positioned to do so. We do not know what data was stored, who was affected, what jurisdictions are implicated, or which notification statutes apply.

All breach notifications — to data subjects, to the State CJIS Systems Agency, to the FBI CJIS Division, to cyber-insurance carriers, to attorneys general under state breach-notification statutes (e.g. Cal. Civ. Code §1798.82, Tex. Bus. & Com. Code §521.053, N.Y. Gen. Bus. Law §899-aa, and equivalent laws in every state), to the press, and to any oversight or prosecutorial bodies — are **agency obligations** and must be executed under the agency's existing breach-response policy. The vendor will not, and cannot, transmit notifications, draft notification letters on the agency's behalf, or determine the scope of who must be notified.

How to Use This Document

This guide mirrors the **MS-ISAC NIST CSF Policy Template Guide (2020)**. It documents how VIPER, when

deployed and operated as recommended, satisfies each applicable NIST CSF subcategory. Agencies adopting VIPER may use this guide as a **supplement** to their existing information-security policy package and CJIS Security Policy.

The guide is scoped to the VIPER application itself. It does **not** address the agency's broader CJIS Security Policy, which governs all CJIS-classified data on the host workstation regardless of which application processes it.

The guide is organized by the five NIST CSF Functions:

Function	Purpose
Identify (ID)	Develop organizational understanding of cybersecurity risk to systems, people, assets, data, and capabilities.
Protect (PR)	Implement safeguards to ensure delivery of critical services.
Detect (DE)	Implement activities to identify the occurrence of a cybersecurity event.
Respond (RS)	Take action regarding a detected cybersecurity incident.
Recover (RC)	Maintain plans for resilience and restoration of capabilities or services impaired by an incident.

Each subcategory (e.g. PR.AC-1) lists:

- **Requirement** — the NIST CSF control text
- **VIPER Control** — how VIPER satisfies the requirement (technical evidence)
- **Policy Statement** — adoptable policy language
- **References** — corresponding SANS/MS-ISAC template names from the source guide

Scope

This policy applies to:

- All deployments of VIPER (per-user, per-machine MSI, and portable USB)
- All officers, detectives, supervisors, and IT personnel using VIPER
- All case data, evidence files, warrant returns, and derivative work product produced or stored within VIPER on agency-controlled devices
- All systems on which VIPER is installed or executed

This policy does **not** apply to, and does not modify:

- The agency's CJIS Security Policy
 - The agency's broader information-security or breach-response policies
 - Any data store outside of VIPER, including agency RMS/CAD, evidence-management systems, or shared-drive content
 - Vendor-controlled infrastructure beyond the licensing/update endpoints described in ID.AM-4 (Intellect LE has no production data store containing agency case content)
-

NIST FUNCTION: Identify (ID)

ID.AM — Asset Management

ID.AM-1 — Physical devices and systems are inventoried.

VIPER Control:

- VIPER's **Settings** → **Licensing** page records the host machine fingerprint and license activation against the Intellect Dashboard at activation time.
- The Intellect Dashboard maintains an inventory of every active VIPER **installation**: customer organization, license type, product version, last-seen timestamp, and registration IP. **This inventory contains licensing metadata only — no agency case data, no subject identities, and no operational content.**
- The dashboard's `/admin/customers` view exports the active-installation roster on agency request.

Policy Statement: The agency shall maintain its **own** authoritative inventory of every workstation, laptop, and removable device on which VIPER is installed (per the agency's CJIS Security Policy asset-management requirements). The vendor's licensing roster may be used as a secondary cross-reference but is not a substitute for the agency's CJIS asset inventory.

References (MS-ISAC): Acceptable Use of Information Technology Resource Policy · Identification and Authentication Policy · Information Security Policy · Security Assessment and Authorization Policy

ID.AM-2 — Software platforms and applications are inventoried.

VIPER Control:

- VIPER reports its installed version and product slug to the Intellect Dashboard via `/api/license/validate` on every launch (when network is available).
- The dashboard tracks `current_version` per product (`project-viper`, `icac-pulse`, `project-oversight`) and surfaces drift to administrators.
- Auto-updater (`electron-updater`) reads `latest.yml` from GitHub Releases — every deployed version is therefore traceable to a signed, published release.

Policy Statement: Only versions of VIPER published to the official GitHub Releases channel for `exhonorated999/project-viper`, signed by the Intellect LE Authenticode certificate, may be installed on agency systems.

References: Information Security Policy · Security Assessment and Authorization Policy

ID.AM-4 — External information systems are catalogued.

VIPER Control: VIPER's external connections fall into four clearly-bounded categories. **No category transmits case content, subject identities, evidence, warrant returns, or narrative text to any Intellect LE-controlled infrastructure.** A complete, canonical inventory (with exact hostnames, what is transmitted, and CJI classification) is maintained in the companion document

[VIPER_Data_Flow_and_Integrations.md](#); the summary below is authoritative for this control.

Category A — Vendor infrastructure (licensing / software distribution). No CJI.

- Intellect Dashboard API (<https://intellect-unified-dashboard-production.up.railway.app/api/>) — license validation/registration and update check. Transmits organization name, license-key hash, product version, machine fingerprint, and request IP only.
- GitHub Releases (<https://github.com/exhonorated999/project-viper>) — signed installer, latest.yml, and on-demand Whisper engine download. Inbound download only.

Category B — Vendor-hosted privacy-preserving broker (opt-in). No plaintext CJI.

- TRACE Network broker (<https://trace-broker-production.up.railway.app>) — optional cross-agency deconfliction. Transmits **one-way SHA-256 token hashes only** (e.g. of a plate or name), never the plaintext value, plus token type/tier/case-type. Disabled until the agency explicitly enables and registers for the TRACE Network.

Category C — Agency-authenticated embedded browser panels (third-party services the agency already licenses). VIPER renders the vendor's own website inside an isolated session partition; the officer signs in with the **agency's own account** and traffic flows **directly between that session and the third party** — VIPER does not proxy, relay, store, or transform it. Functionally equivalent to opening the site in Edge/Chrome. Each service uses a dedicated, isolated session partition (`persist:<service>`):

- Flock Safety LPR — search-2.flocksafety.com
- TLOxp — tloxp.tlo.com
- Accurint (LexisNexis) — secure.accurint.com
- Whooster — app.whooster.com
- Vigilant / Motorola VehicleManager — vm.motorolasolutions.com
- ICAC Data System — icacdatasystem.com
- ICAC COPS — icaccops.com
- GridCop — gridcop.com
- Callyo — callyo.com

Category D — Officer-initiated OSINT / enrichment lookups (query terms only, using the agency's own API credentials where applicable).

- WiGLE (api.wigle.net) — Wi-Fi/BT/cell geolocation; transmits BSSID/SSID.
- GenLogs (api.genlogs.io) — commercial-vehicle sightings; transmits USDOT/MC/plate.
- ARIN WHOIS (whois.arin.net) — transmits an IP address.
- FMCSA SAFER (safer.fmcsa.dot.gov) — transmits a carrier name/number.
- IP geolocation (ip-api.com) — transmits an IP address.
- OpenStreetMap Nominatim (nominatim.openstreetmap.org) — geocoding; transmits an address string.
- Map tiles / routing (*.tile.openstreetmap.org, *.basemaps.cartocdn.com, router.project-osrm.org) — transmits coordinates only.

Enforcement: Each application page ships a Content-Security-Policy meta tag whose `connect-src` directive whitelists the Category A/B/D endpoints above; renderer fetches to any other origin are blocked by the browser engine. Category C services are loaded in dedicated `BrowserView` session partitions (isolated cookies/storage per service) rather than via renderer fetch. Categories B, C, and D are **opt-in / user-**

initiated and can be individually disabled by the agency.

Policy Statement: VIPER's outbound network access is limited to the four categories above. Agencies may further restrict via firewall/proxy to exclude any Category C or Category D endpoint not in use, and may disable the TRACE Network (Category B) entirely. The agency's existing CJIS agreements with the Category C service providers (Flock, LexisNexis/Accurint, TLOxp, Motorola/Vigilant, etc.) remain the controlling authority for data exchanged with those services; VIPER neither expands nor alters those relationships.

References: System and Communications Protection Policy

ID.AM-5 — Resources are prioritized based on classification, criticality, and business value.

VIPER Control:

- VIPER cases carry an **Operations Plan** module supporting case-criticality ratings.
- Custom Metrics (per-case tagging) lets agencies define classification labels (e.g. "DA Accepted", "Active Surveillance", "Cold").
- Case status taxonomy supports Open / Suspended / Closed / Closed w/ Arrest / Inactive — surfaced in dashboard rollups.

Policy Statement: All cases shall be classified using the agency's information-classification scheme. Custom Metrics shall be configured to mirror that scheme.

References: Acquisition Assessment Policy · Information Classification Standard · Information Security Policy

ID.AM-6 — Cybersecurity roles and responsibilities are established.

Policy Statement [AGENCY-SPECIFIC]:

- **CJIS Systems Officer (CSO) / Local Agency Security Officer (LASO)** — owns CJIS-Security-Policy compliance for every workstation that runs VIPER; owns incident response and breach notification.
- **System Owner** — Agency IT Director: approves installations, manages MSI deployment, owns endpoint hardening and EDR coverage.
- **Application Administrator** — Designated officer or sworn supervisor: manages license keys, custom metrics, settings rollouts, and Field Security policy on the agency side.
- **End Users** — Officers/detectives: case data entry, evidence intake, warrant parsing, local audit-log review.
- **Vendor — Intellect LE, LLC** — supplies the application, signs and publishes releases, validates licenses, and maintains supply-chain integrity. **The vendor has no access to agency case data, no operational visibility into installations, and no role in agency incident response or breach notification.** See the "Vendor Boundary & Offline Architecture" section above.
- **Third-Party Stakeholders** — DA's Office (case exports), partner agencies (canvas forms, sealed-case sharing) — receive data only via agency-initiated export.

References: Acceptable Use Policy · Information Security Policy · Security Awareness and Training Policy

ID.RM — Risk Management Strategy

ID.RM-1 — Risk management processes are established.

Policy Statement [AGENCY-SPECIFIC]: The agency shall conduct an annual risk assessment of its VIPER deployment covering:

- Field Security activation rate (% of installations with encryption enabled)
- License compliance (active vs. expired)
- Auto-updater effectiveness (% of installations on current version)
- Audit log retention compliance
- Incident response drills

References: Information Security Risk Management Standard · Risk Assessment Policy

ID.SC — Supply Chain Risk Management

ID.SC-2 — Suppliers and third-party partners are identified and assessed.

VIPER Control: Vendor due-diligence package available from Intellect LE on request, covering:

- Build pipeline integrity (signed releases, reproducible builds from public source)
- Dependency provenance (`package-lock.json`, `npm audit` reports per release)
- Code-signing chain of custody (Authenticode cert held by Intellect LE)

Policy Statement: Before initial deployment and at each major version upgrade, the agency shall review the Intellect LE due-diligence package. This guide and the corresponding release notes constitute that package.

References: Acquisition Assessment Policy · Systems and Services Acquisition Policy

ID.SC-4 — Suppliers and third-party partners are routinely assessed.

Policy Statement [AGENCY-SPECIFIC]: Annually, the agency shall confirm:

- Intellect LE Authenticode certificate is current
- VIPER GitHub repository remains under `exhonorated999/project-viper` (no transfer of ownership)
- Dashboard endpoint TLS certificate is valid and chains to a trusted CA

ID.SC-5 — Response and recovery planning is conducted with suppliers.

VIPER Control: Intellect LE's incident-response scope is limited to its own supply-chain integrity (build pipeline, code-signing certificate, release artifacts, dashboard endpoints). Intellect LE does **not** provide incident response for agency case data, agency networks, agency endpoints, or any CJIS-classified information — and is not capable of doing so because the vendor has no access to that data (see "Vendor

Boundary" section above).

Policy Statement: In the event of a suspected **vendor-side** / **supply-chain** compromise (e.g. unauthorized release published, code-signing certificate revoked, dashboard endpoint compromise), the agency shall:

1. Halt auto-updates by setting `VIPER_DISABLE_AUTOUPDATE=1` in machine env or via GPO.
2. Notify Intellect LE through the published vendor contact channel so the vendor can investigate the supply-chain side.
3. Preserve local installations unchanged for the agency's own forensic review under the agency CJIS-compliant incident-response plan.

For a suspected **agency-side** compromise (lost device, unauthorized access, suspected exfiltration of case data), the agency executes its own incident-response plan; the vendor cannot assist (see RS section).

NIST FUNCTION: Protect (PR)

PR.AC — Identity Management and Access Control

PR.AC-1 — Identities and credentials are issued, managed, verified, revoked, and audited.

VIPER Control:

- Each VIPER installation requires an **API Key** (`INT-XXXX-XXXX-XXXX-XXXX`) and **License Key** (`INT-VIPER-XXXX-XXXX-XXXX`) issued by the Intellect Dashboard.
- License keys are SHA-256 hashed before storage on the dashboard — raw keys are never persisted server-side after issuance.
- Field Security identifier (case-cipher key) is derived from a user-supplied passphrase; never transmitted off-device.
- Revocation: dashboard administrators may set license `status=revoked` — VIPER refuses to start on next launch when validation fails.

Policy Statement: License keys shall be issued only to named individual officers or named workstations. Shared license keys are prohibited. Departed personnel's license keys shall be revoked within 24 hours of separation.

References: Access Control Policy · Account Management/Access Control Standard · Authentication Tokens Standard · Identification and Authentication Policy

PR.AC-3 — Remote access is managed.

VIPER Control:

- VIPER does not expose any inbound network listener — there is no remote-access surface to the application.
- The only remote-accessible endpoints are the Intellect Dashboard (TLS-only, JWT for admin, X-API-Key for desktop apps) and GitHub Releases (HTTPS).

- Canvas Forms (officer-facing form pages) are public by URL but expire after 48 hours and are deleted from the server on download.

Policy Statement: Remote access to VIPER hosts shall follow agency remote-access policy. VIPER's own functionality requires no inbound remote access.

References: Remote Access Policy · Remote Access Standard

PR.AC-4 — Access permissions follow least privilege and separation of duties.

VIPER Control:

- Default install (NSIS, per-user) writes only to the user's %LOCALAPPDATA%\Programs\V.I.P.E.R\ and %APPDATA%\V.I.P.E.R\ — no admin rights required, no machine-wide write access.
- MSI deployment (per-machine) is an IT-managed action; officers do not gain elevation from the application.
- Auto-updater requests UAC elevation **only** at the moment of update install (NSIS `Start-Process -Verb RunAs`); the running app does not retain elevation.
- Field Security separates case-data ciphertext from access — even a system administrator cannot read ciphertext without the user's passphrase.

Policy Statement: Officer accounts on VIPER hosts shall be standard (non-admin) accounts. Admin accounts shall be used only for installation, MSI deployment, or troubleshooting under change control.

References: Access Control Policy · Account Management/Access Control Standard · Secure Configuration Standard

PR.AC-5 — Network integrity is protected (segregation/segmentation).

Policy Statement [AGENCY-SPECIFIC]: Hosts running VIPER shall reside on the agency's law-enforcement VLAN with egress filtered to the published external dependency list (see ID.AM-4).

References: Lab Security Policy · Mobile Device Security · System and Information Integrity Policy

PR.AT — Awareness and Training

PR.AT-1 — All users are informed and trained.

VIPER Control:

- Built-in onboarding tutorial on first launch.
- In-app **Resource Hub** with documentation for each module.
- Settings page contextual help for Field Security activation.
- Update warning banner: "Back up your data before updating."

Policy Statement [AGENCY-SPECIFIC]: Before being issued a VIPER license key, every officer shall complete:

1. The agency's information-security awareness training.
2. The Intellect LE VIPER training video series.
3. A documented review of this policy guide.

References: Acceptable Use Policy · Information Security Policy · Personnel Security Policy · Security Awareness and Training Policy

PR.DS — Data Security

PR.DS-1 — Data-at-rest is protected.

VIPER Control:

- **Field Security** (when enabled) encrypts every case-data file written to disk with **AES-256-GCM**.
- VIPENC magic header (6 bytes: V,I,P,E,N,C) plus version byte and 12-byte IV identify each encrypted blob.
- Encryption is applied transparently at the IPC boundary in the Electron main process — case modules never see plaintext on disk.
- Cases folder is hidden via `attrib +H` while Field Security is active (Windows).
- Master passphrase is processed via PBKDF2 / `scrypt` and never stored in plaintext.

Policy Statement: Field Security shall be enabled on every VIPER installation handling case data of any sensitivity above public-record. Master passphrases shall meet the agency's password-construction guideline.

References: Encryption Standard · Information Security Policy · Media Protection Policy · Mobile Device Security

PR.DS-2 — Data-in-transit is protected.

VIPER Control:

- All outbound traffic is TLS-only (HTTPS) — Intellect Dashboard, GitHub, ARIN, Nominatim.
- Content Security Policy meta tag denies any non-HTTPS external resource.
- Canvas Form submissions are TLS-protected end-to-end (officer phone → dashboard → detective workstation).
- License validation includes timestamp + nonce to prevent replay.

Policy Statement: VIPER shall not be configured to use any non-TLS transport. Agencies operating self-hosted dashboards shall maintain a valid CA-issued TLS certificate.

References: Encryption Standard · Information Security Policy · System and Communications Protection Policy

PR.DS-3 — Assets are formally managed throughout removal, transfers, and disposition.

VIPER Control:

- Case **Export** (`.vcase`) packages all module data into a single signed JSON file for transfer.
- Case **Import** validates structure, prompts on duplicate case numbers, never silently overwrites.
- **Backup** (`.vbak`) packages the entire user database for migration.
- License revocation on the dashboard immediately disables the source installation; case data on the originating device must be wiped per agency disposal policy.

Policy Statement: When a workstation is decommissioned, IT shall:

1. Export all cases the user owns (`.vcase` per case or `.vbak` whole-system backup) and verify import integrity on the receiving system.
2. Revoke the source workstation's license on the Intellect Dashboard.
3. Securely wipe the workstation per agency media-protection policy.

References: Acquisition Assessment Policy · Technology Equipment Disposal Policy · Sanitization Secure Disposal Standard

PR.DS-7 — Development and testing environments are separate from production.

VIPER Control: Intellect LE maintains separate dashboards for development (`localhost:3000`), staging, and production. Released VIPER builds point exclusively at production.

Policy Statement [AGENCY-SPECIFIC]: Agencies shall not deploy unsigned/development VIPER builds to production endpoints handling real case data.

PR.DS-8 — Integrity-checking mechanisms verify hardware/software integrity.

VIPER Control:

- VIPER installer + `latest.yml` are SHA-512 hashed; electron-updater verifies hash before applying any update.
- `verifyUpdateCodeSignature: true` rejects any installer not signed by the running app's publisher (Intellect LE).
- ASAR archive integrity is enforced at app launch (Electron 28+).
- Per-case auto-snapshot to disk every N minutes; recovery requires user-initiated action (not automatic on launch).

Policy Statement: Auto-update integrity verification shall remain enabled. Any installer not signed by Intellect LE shall not be installed.

References: Acquisition Assessment Policy · System and Information Integrity Policy

PR.IP — Information Protection Processes and Procedures

PR.IP-1 — Baseline configuration is created and maintained.

VIPER Control:

- VIPER ships with a documented secure default: Field Security off (must be explicitly enabled), auto-update on, telemetry off, media-player off, all optional integrations off.
- `electron-builder.yml` documents the build-time configuration baseline (file allow-list, asarUnpack rules, signing flags, data-preservation policy).
- `installer.nsh` documents the install-time baseline (per-user install path, data preservation across upgrade/uninstall, process-kill on install).

Policy Statement: The agency baseline shall override the secure default by enabling Field Security on first launch. All other settings shall remain at default unless explicitly approved.

References: Configuration Management Policy · Secure Configuration Standard · Secure System Development Life Cycle Standard

PR.IP-4 — Backups of information are conducted, maintained, and tested.

VIPER Control:

- **Per-case auto-snapshots** to disk every interval (configurable in Settings).
- **Manual backup** via Settings → Backup (`.vbak` includes all Pattern 1 and Pattern 2 keys: cases, evidence index, KIK/Google/Discord/Snapchat warrant data, custom metrics, oversight imports, etc.).
- **Per-case export** via `.vcase` for granular handoff.
- Snapshot recovery is **user-initiated only** (Settings button) — never automatic on launch — to prevent accidental rollback.

Policy Statement: Officers shall create a manual `.vbak` backup at minimum weekly. Backups shall be stored on agency-approved media (encrypted external drive or NAS). Backups shall be test-restored quarterly.

References: Disaster Recovery Plan Policy · Information Security Policy

PR.IP-6 — Data is destroyed according to policy.

VIPER Control:

- Case deletion in VIPER cascades through both Pattern 1 (shared `viperCase*` keys) and Pattern 2 (`<module>_<caseId>` keys), removing all associated `localStorage` entries.
- Evidence files on disk under `cases/<caseNumber>/` are deleted with the case folder.
- Canvas form submissions are **deleted on download** from the dashboard.
- Expired canvas forms are auto-deleted by the dashboard's hourly cleanup task.

Policy Statement: Cases retained beyond the agency's retention period shall be deleted using VIPER's case-delete function followed by the agency's media-sanitization procedure for the underlying disk space.

References: Technology Equipment Disposal Policy · Media Protection Policy · Sanitization Secure Disposal Standard

PR.IP-9 — Response/recovery plans are in place and managed.

VIPER Control (vendor side): None — the vendor has no operational visibility into agency installations, no access to case data, and no ability to remotely investigate or remediate (see "Vendor Boundary" section). The vendor maintains its own supply-chain incident-response plan covering build/sign/release integrity only.

Policy Statement [AGENCY-SPECIFIC]: The **agency** shall maintain a written incident-response plan, owned by the CSO/LASO and aligned to the FBI CJIS Security Policy §5.3, that addresses the following VIPER-related scenarios:

Scenario	Owner	Vendor Role
Lost or stolen device with VIPER installed	Agency	License revocation on agency request; otherwise none
Suspected unauthorized access to a case	Agency	None
Suspected compromise of an officer's master passphrase	Agency	None
Suspected exfiltration of CJIS data from a VIPER host	Agency (notify CSA + FBI per CJIS §5.3)	None
Compromise of the Intellect Dashboard licensing endpoint	Agency halts auto-updates; vendor investigates own infrastructure	Supply-chain investigation only
Unauthorized release published to GitHub	Agency halts auto-updates; vendor revokes release	Supply-chain investigation only
Loss of case data (corruption, deletion, ransomware)	Agency (recover from .vbak/.vcase)	None

The vendor cannot perform breach notifications, cannot determine which subjects/cases were affected, and cannot characterize the scope of any exposure because no such data exists on vendor-controlled systems. All notifications under state, federal, and CJIS authority are agency obligations.

References: Data Breach Response Policy · Disaster Recovery Plan Policy · Security Response Plan Policy · Incident Response Policy · FBI CJIS Security Policy §5.3

PR.IP-10 — Response and recovery plans are tested.

Policy Statement [AGENCY-SPECIFIC]: The agency shall conduct an annual tabletop exercise covering at minimum one of the PR.IP-9 scenarios, with documented after-action review.

PR.MA — Maintenance

PR.MA-2 — Remote maintenance is approved, logged, and performed in a manner that prevents unauthorized access.

VIPER Control:

- VIPER does not include any remote-maintenance backdoor.

- Auto-update is the only remote-maintenance channel; updates require valid Intellect LE Authencodex signature and matching SHA-512 hash.
- Each update install is logged in the VIPER **Audit Log** (`modules/audit-log.js`) with version transition and timestamp.

Policy Statement: No remote-maintenance tool other than VIPER's signed auto-updater shall be permitted to modify the VIPER installation.

References: Remote Access Policy · Maintenance Policy · Security Logging Standard

PR.PT — Protective Technology

PR.PT-1 — Audit/log records are determined, documented, implemented, and reviewed.

VIPER Control:

- **Audit Log module** (`modules/audit-log.js`) records: module access, evidence intake, evidence export, case export, case import, license events, security events, settings changes.
- Logs are stored locally per-installation; agencies may export to SIEM via the agency's standard endpoint-log pipeline.
- The Intellect Dashboard's `AuditLog` table records admin actions on the dashboard side (license issuance, customer changes, release uploads).

Policy Statement: Audit logs shall be retained for the period required by agency retention policy (minimum 1 year recommended). Logs shall be reviewed at least monthly by a designated supervisor.

References: Information Logging Standard · Auditing and Accountability Standard · Security Logging Standard

PR.PT-2 — Removable media is protected and use restricted.

VIPER Control:

- VIPER **Portable Mode** runs entirely from removable media (USB drive). Detection is automatic for non-system drives; explicit override via `.portable` marker file.
- Portable installs preserve `userdata/` and `cases/` on the USB drive — no data leaks to the host.
- Field Security applies identically to portable mode (passphrase required to open cases regardless of drive).

Policy Statement: When VIPER is run from removable media, the media shall be hardware-encrypted (FIPS 140-2 Level 2 or higher). Field Security shall be enabled. The media shall be tracked under the agency's removable-media inventory.

References: Acceptable Use Policy · Media Protection Policy · Mobile Device Security

PR.PT-4 — Communications and control networks are protected.

VIPER Control: All outbound communication is TLS (see PR.DS-2). VIPER does not implement any control-network protocol.

References: Encryption Standard · System and Communications Protection Policy

PR.PT-5 — Resilience mechanisms are implemented.

VIPER Control:

- Per-case auto-snapshots provide point-in-time recovery.
- License validation falls back to a cached "last-known-valid" timestamp for up to 7 days to prevent network-outage lockout.
- Auto-updater fallback chain: PowerShell elevated install → cached installer launch → `quitAndInstall` graceful retry.
- Installer preserves user data across upgrade and reinstall (`deleteAppDataOnUninstall: false`, NSIS data backup/restore via `CopyFiles /SILENT`).

References: Disaster Recovery Plan Policy · Security Response Plan Policy

NIST FUNCTION: Detect (DE)

DE.AE — Anomalies and Events

DE.AE-3 — Event data is collected and correlated from multiple sources.

VIPER Control:

- Audit Log captures application events.
- Warrant parser modules (Discord, KIK, Google, Snapchat, Meta) ingest external event streams (sessions, IPs, devices) into a unified case timeline.
- Case **Timeline Events** module correlates manually-entered events with parsed warrant events.
- ARIN WHOIS lookup enriches IPs across all warrant parser modules with consistent provider/network/range data.

Policy Statement: Officers shall correlate warrant-return event data within VIPER's Timeline Events module rather than maintaining parallel external spreadsheets.

References: Information Logging Standard · Auditing and Accountability Standard · Vulnerability Scanning Standard

DE.CM — Security Continuous Monitoring

DE.CM-1 — The network is monitored for cybersecurity events.

Policy Statement [AGENCY-SPECIFIC]: Hosts running VIPER shall be monitored by the agency's EDR/

AV solution. VIPER does not provide its own network monitoring.

References: Information Security Policy · Vulnerability Scanning Standard

DE.CM-4 — Malicious code is detected.

VIPER Control:

- VIPER asserts ASAR integrity at launch (Electron 28+).
- Auto-updater rejects any installer with a hash mismatch or invalid Authenticode signature.
- The application does not execute downloaded scripts; all warrant-parser code is bundled and signed.

Policy Statement: Agency EDR shall be permitted to scan VIPER's installation directory and runtime processes. VIPER's exclusions list shall be limited to known false-positive paths (e.g. ASAR archive scans on launch).

References: Auditing and Accountability Standard · Secure Coding Standard · System and Information Integrity Policy

DE.CM-7 — Monitoring for unauthorized personnel, connections, devices, and software.

VIPER Control: License validation events on the dashboard reveal unauthorized installation attempts (failed validation by IP, agent, fingerprint). Dashboard administrators see these in the `AuditLog` table.

Policy Statement: Dashboard administrators shall review failed license-validation events weekly and investigate any pattern indicating credential compromise.

DE.DP — Detection Processes

DE.DP-1 — Roles and responsibilities for detection are defined.

Policy Statement [AGENCY-SPECIFIC]:

- **Officer** — reports anomalous VIPER behavior to supervisor.
- **Supervisor** — escalates to agency IT and CSO/LASO.
- **Agency IT / CSO / LASO** — investigates, executes the agency CJIS-compliant incident-response plan, and contacts Intellect LE only if a **supply-chain** question (signed-build integrity, license-system status) requires vendor input. Detection, investigation, containment, and remediation of agency-side events stay with the agency.

References: Incident Response Policy · Information Security Policy

DE.DP-4 — Event detection information is communicated.

Policy Statement [AGENCY-SPECIFIC]: Confirmed VIPER-related security events shall be communicated

through the agency's existing CJIS-compliant notification chain, typically:

- Affected officers (within 24 hours)
- Agency CSO/LASO and CISO/IT director (immediately)
- State CJIS Systems Agency / FBI CJIS Division (per CJIS §5.3 thresholds)
- DA's office (if affected cases include active prosecution)
- Cyber-insurance carrier (per policy terms)

The vendor is **not** a recipient in this chain. The agency may separately contact Intellect LE for license actions or supply-chain inquiries; that contact is informational and does not relieve the agency of any CJIS or statutory notification obligation.

NIST FUNCTION: Respond (RS)

Vendor scope reminder: Every subcategory in this Function is the **agency's** responsibility. Intellect LE has no access to case data, no telemetry on case content, no ability to perform investigations, and no ability to issue notifications on the agency's behalf. The vendor's only response capability is supply-chain investigation of its own build/sign/release pipeline. The agency executes the response plan under its existing CJIS Security Policy.

RS.RP — Response Planning

RS.RP-1 — Response plan is executed.

VIPER Control (vendor side): None.

Policy Statement [AGENCY-SPECIFIC]: Upon detection of a VIPER-related cybersecurity incident, the agency's CSO/LASO and on-call IT analyst shall execute the **agency's** incident-response plan (treating VIPER as an in-scope endpoint application per PR.IP-9). The vendor is not part of the response chain except to receive a license-revocation request or a supply-chain-integrity inquiry. Do **not** wait on the vendor before acting — VIPER is offline by design and vendor coordination is not a prerequisite to any agency response action.

References: Security Response Plan Policy · Incident Response Policy · Planning Policy · FBI CJIS Security Policy §5.3

RS.CO — Communications

RS.CO-1 — Personnel know their roles and order of operations.

Policy Statement: Per DE.DP-1 and ID.AM-6 above. All response roles sit inside the agency. The vendor is not a response role. Roles shall be exercised annually per PR.IP-10.

RS.CO-2 — Incidents are reported consistent with established criteria.

Policy Statement [AGENCY-SPECIFIC]: Reportable VIPER-related incidents include (non-exhaustive):

- Lost/stolen device with VIPER installed
- Suspected unauthorized case access
- Suspected master-passphrase compromise
- Suspected exfiltration of CJIS data from a VIPER host
- Auto-updater installing an unsigned/unexpected version
- Persistent license-validation failure suggesting dashboard compromise

Reporting chain (agency-internal first):

1. Officer → Supervisor → Agency IT/CSO/LASO
2. CSO/LASO determines whether the incident meets CJIS §5.3 reporting thresholds and, if so, reports to the **State CJIS Systems Agency (CSA)** and onward to the **FBI CJIS Division** per the agency's CJIS-compliant timetable.
3. CSO/LASO determines breach-notification obligations under applicable state breach-notification statutes and executes notifications.
4. The agency may notify Intellect LE only for license revocation or supply-chain integrity questions.
The vendor is not a substitute for, and does not replace, any CJIS or statutory reporting channel.

The vendor will not draft, send, or coordinate breach notifications. The vendor cannot determine the scope of affected subjects because no subject data exists on vendor-controlled systems.

References: Data Breach Response Policy · Security Response Plan Policy · Incident Response Policy · FBI CJIS Security Policy §5.3 · Applicable state breach-notification statutes

RS.CO-3 — Information is shared consistent with response plans.

RS.CO-4 — Coordination with stakeholders occurs.

RS.CO-5 — Voluntary information sharing occurs with external stakeholders.

Policy Statement: Information sharing with the State CSA, FBI CJIS Division, MS-ISAC, partner agencies, prosecuting attorneys, and cyber-insurance carriers shall follow the agency's CJIS-compliant information-sharing policy. **Intellect LE is not in the information-sharing chain for incident data** because no agency case content exists on vendor systems. Communication with the vendor is limited to license actions and supply-chain integrity inquiries.

RS.AN — Analysis

RS.AN-4 — Incidents are categorized consistent with response plans.

Policy Statement [AGENCY-SPECIFIC]: The agency shall categorize VIPER-related incidents using its standard CJIS incident taxonomy with a mandatory "VIPER" tag for trend analysis. Categorization is an agency function; the vendor has no inputs.

RS.IM — Improvements

RS.IM-1 — Response plans incorporate lessons learned.

RS.IM-2 — Response strategies are updated.

Policy Statement: After-action reviews from PR.IP-10 exercises and from real incidents shall feed updates to the **agency's** incident-response plan. Where lessons learned identify a documentation gap in this guide (e.g. an undocumented VIPER behavior the agency needed to know during response), the agency may submit the gap to Intellect LE for inclusion in the next revision.

NIST FUNCTION: Recover (RC)

Vendor scope reminder: Recovery is an agency function executed against agency-controlled local data using agency-controlled local backups. Intellect LE has no remote-recovery capability, no copy of agency case data, and no ability to restore lost cases. The vendor's role is limited to: (a) supplying signed installers from the official release channel, and (b) issuing a replacement license key on documented agency request.

RC.RP — Recovery Planning

RC.RP-1 — Recovery plan is executed during or after a cybersecurity incident.

VIPER Control (local recovery tools — executed by agency, on agency hardware):

- Restore from `.vbak` backup (Settings → Restore).
- Restore individual cases from `.vcase` exports.
- Restore from per-case auto-snapshot via Settings → Snapshot Recovery (user-initiated).
- Reinstall from signed installer; user data is preserved (`deleteAppDataOnUninstall: false`).

Vendor recovery capability: None. There is no cloud backup. There is no vendor-side copy of any case. Recovery integrity depends entirely on the agency's local-backup discipline (PR.IP-4).

Policy Statement [AGENCY-SPECIFIC]: Recovery from a compromised installation shall be executed by agency IT under the agency's CJIS-compliant recovery procedure, in this order:

1. Quarantine the affected workstation.
2. Confirm the latest agency-controlled `.vbak` backup is intact and pre-compromise.
3. Wipe and reimage the workstation per the agency's media-sanitization policy (CJIS §5.8).
4. Reinstall VIPER from the signed installer (verify Authenticode signature before install).
5. Restore from the verified `.vbak` backup.
6. Request a new license key from Intellect LE (revoking the old one) before bringing the workstation back online.

References: Disaster Recovery Plan Policy · Contingency Planning Policy · Incident Response Policy · FBI CJIS Security Policy §5.8

RC.IM — Improvements

RC.IM-1 — Recovery plans incorporate lessons learned.

RC.IM-2 — Recovery strategies are updated.

Policy Statement: Annual review of the agency's recovery procedures shall incorporate lessons from any executed recoveries during the prior year. The agency may submit documentation gaps in this guide to Intellect LE for inclusion in the next revision.

RC.CO — Communications

RC.CO-1 — Public relations are managed.

RC.CO-2 — Reputation is repaired after an incident.

RC.CO-3 — Recovery activities are communicated to internal and external stakeholders.

Policy Statement [AGENCY-SPECIFIC]: Public communications regarding any VIPER-related incident shall be coordinated through the agency's public-information officer (PIO) under the agency's existing media-relations policy. **Intellect LE will not issue public statements about agency incidents** because the vendor has no facts to attest to — no case data, no telemetry, no visibility into the affected installation. The vendor will respond only to direct questions about the application's documented security architecture (this guide). The agency's PIO is the sole authoritative voice regarding the incident's scope, affected subjects, and notification status.

Appendix A — Mapping Summary (NIST CSF Subcategory → VIPER Control)

NIST	Subcategory	Primary VIPER Control
ID.AM-1	Device inventory	Dashboard customer roster
ID.AM-2	Software inventory	Version-validation API + GitHub Releases
ID.AM-4	External systems catalogued	CSP whitelist + documented dependencies
ID.AM-5	Resource prioritization	Custom Metrics + case status taxonomy
ID.AM-6	Roles and responsibilities	Agency-specific policy section
ID.RM-1	Risk management process	Annual review checklist

ID.SC-2	Supplier assessment	Vendor due-diligence package
ID.SC-4	Supplier reassessment	Annual cert/repo/TLS review
ID.SC-5	Supplier IR coordination	Vendor scope limited to supply-chain (build/sign/release); agency owns operational IR
PR.AC-1	Identity management	API key + License key + dashboard revocation
PR.AC-3	Remote access	No inbound surface
PR.AC-4	Least privilege	Per-user install, no app elevation
PR.AC-5	Network segregation	Agency VLAN
PR.AT-1	Awareness/training	Onboarding tutorial + agency training
PR.DS-1	Data-at-rest	Field Security AES-256-GCM
PR.DS-2	Data-in-transit	TLS-only + CSP enforcement
PR.DS-3	Asset disposition	.vcase / .vbak + license revocation
PR.DS-7	Dev/test/prod separation	Separate dashboards
PR.DS-8	Integrity checks	Authenticode + SHA-512 + ASAR
PR.IP-1	Baseline configuration	Documented secure default
PR.IP-4	Backups	.vbak + auto-snapshots
PR.IP-6	Data destruction	Cascade delete + canvas TTL
PR.IP-9	Response/recovery plans	Agency policy + this guide
PR.IP-10	Plan testing	Annual tabletop
PR.MA-2	Remote maintenance	Signed auto-updater only
PR.PT-1	Audit logs	modules/audit-log.js
PR.PT-2	Removable media	Portable mode + hardware-encrypted USB
PR.PT-4	Comms protection	TLS-only
PR.PT-5	Resilience	Snapshots + cached license + installer fallback
DE.AE-3	Event correlation	Timeline + warrant parsers + ARIN
DE.CM-1	Network monitoring	Agency EDR (out of scope for VIPER)
DE.CM-4	Malicious code detection	ASAR integrity + signed-update enforcement
DE.CM-7	Unauthorized monitoring	Dashboard validation logs
DE.DP-1	Detection roles	Agency-specific policy section
DE.DP-4	Detection comms	Agency notification chain
RS.RP-1	Response execution	Agency IR plan

RS.CO-1..5	Response comms	Agency comms plan
RS.AN-4	Incident categorization	Agency taxonomy + "VIPER" tag
RS.IM-1/2	Response improvement	Document version history
RC.RP-1	Recovery execution	. vbak restore + reissue license
RC.IM-1/2	Recovery improvement	Annual review
RC.CO-1..3	Recovery comms	Agency PIO coordination

Appendix B — Adoption Checklist

Before placing VIPER into operational use, the agency shall confirm:

Vendor-boundary acknowledgments

- ☐ CSO/LASO has read and approved the "Vendor Boundary & Offline Architecture" section above
- ☐ Agency leadership understands that Intellect LE has **no access** to agency case data and **no role** in incident response or breach notification
- ☐ Agency leadership understands that **all CJIS compliance** for VIPER hosts is owned by the agency under its existing CJIS Security Policy
- ☐ Agency leadership understands that **all breach-notification obligations** (CJIS, state, federal, contractual) are agency obligations and **cannot be performed by the vendor**

Operational baseline

- ☐ License keys issued only to named officers/workstations
- ☐ Field Security enabled on all installations
- ☐ Master passphrases meet agency password-construction guideline
- ☐ Auto-update integrity verification enabled (default)
- ☐ CSP whitelist not relaxed
- ☐ Outbound firewall rules align with documented dependency list (ID.AM-4)
- ☐ Backup schedule established (PR.IP-4) — backups are the **only** path to data recovery; there is no vendor-side copy
- ☐ Audit log retention configured locally per agency CJIS retention policy (PR.PT-1)

Agency-owned response artifacts

- ☐ Agency incident-response plan addresses VIPER scenarios (PR.IP-9)
- ☐ CJIS §5.3 reporting chain documented (CSO → CSA → FBI)
- ☐ State breach-notification statute(s) identified and reporting playbook drafted
- ☐ Cyber-insurance reporting trigger documented
- ☐ PIO playbook covers VIPER-incident scenarios (RC.CO)

Documentation & approval

- ☐ Vendor due-diligence package on file (ID.SC-2)

- [] All sections marked **[AGENCY-SPECIFIC]** have been customized
- [] Document approved by agency CSO/LASO and CISO/Information Security Officer

Appendix C — Document History

Version	Date	Changes
1.0	2026-05-06	Initial release. Aligned to MS-ISAC NIST CSF Policy Template Guide (2020-07-20). Covers VIPER v3.1.0.
1.1	2026-05-07	Added "Vendor Boundary & Offline Architecture" section. Reframed RS (Respond) and RC (Recover) Functions to make explicit that all incident response, breach notification, and recovery are agency obligations under the agency's CJIS Security Policy. Removed any language implying vendor-side incident response, vendor-led notifications, or vendor coordination as a prerequisite to agency action. Added explicit CJIS §5.3 / state breach-notification-statute references. Expanded Appendix B with vendor-boundary acknowledgments.
1.2	2026-07-24	Rewrote ID.AM-4 with the complete, code-verified external-connection inventory, organized into four bounded categories (vendor infrastructure; privacy-preserving TRACE broker; agency-authenticated embedded browser panels; officer-initiated OSINT lookups) with exact hostnames and per-endpoint data-transmission/CJI classification. Documented the embedded-panel model (isolated <code>BrowserView</code> session partitions, agency's own credentials, direct agency↔vendor traffic — not a vendor data integration) and clarified that <code>CSP_{connect-src}</code> enforcement covers renderer fetches while Category C services load in isolated partitions. Introduced companion documents <code>VIPER_Data_Flow_and_Integrations.md</code> and <code>VIPER_Architecture_and_Security.md</code> . Covers VIPER v4.0.8.

This guide is provided by Intellect LE, LLC for use by agencies adopting VIPER. It is a template; adopting agencies are responsible for tailoring it to their own legal, regulatory, and operational requirements. The NIST Cybersecurity Framework is a publication of the U.S. National Institute of Standards and Technology. The policy template references in this document map to the SANS Institute / MS-ISAC policy templates; agencies seeking the underlying templates should consult cisecurity.org/ms-isac/.

--	--	--